Université de Rouen Normandie

SSL Checker

CAHIER DE RECETTE

CAHIER DE RECETTE

Étudiants :
Mehdi LASMI
Marzouk MONIR
Malik MAHFOUDI
Karina AIT-ABDELKAOUI
Naby TRAORE SAVANE
Rayan BOUGHANEM
Hamza RAHMOUNI
Amr ELGOHARY

Client :
Bruno MACADRÉ

27 décembre 2025

Table des matières

1 Introduction **3**

1.1 Fonctions et Actions Principales . . . 3

1.2 Modules à Tester . . . 3

1.3 Environnement et Technologies Utilisées . . . 3

2 Documents applicables et de référence **4**

3 Terminologie et sigles utilisés **4**

4 Environnement de test **4**

4.1 Site et Plateforme de Test . . . 4

4.2 Configurations Matérielles et Logicielles Utilisées . . . 5

4.3 Jeu de Données de Test . . . 5

4.4 Contraintes à Prendre en Compte . . . 5

5 Responsabilités **5**

5.1 Conception des tests . . . 5

5.2 Fourniture des données de test . . . 5

5.3 Exécution des tests . . . 5

6 Stratégie de tests **6**

6.1 Approche et Phases . . . 6

6.2 Ordre d'exécution . . . 6

7 Gestion des anomalies **6**

8 Procédures de test **6**

8.1 Module TestCertificat (Certificat) . . . 6

8.2 Module TestProtocole (Protocoles) . . . 8

8.3 Module TestCipher (Cipher Suites) . . . 8

8.4 Module TestKeyExchange (Échange de clé) . . . 8

8.5 Module TestVulnerabilites (Vulnérabilités) . . . 9

8.6 Module Scanner de Ports (Ports) . . . 10

8.7 Module TestCompatibiliteOS (Compatibilité OS) . . . 10

9 Jeux de données de test **10**

9.1 Module Certificat . . . 10

9.2 Module Protocoles . . . 10

9.3 Module Cipher Suites . . . 11

9.4 Module Echange de clé . . . 11

9.5 Module Vulnérabilités . . . 11

9.6 Module Scan de Ports 11
9.7 Module Compatibilité OS 11

10 Couverture de tests **11**

1 Introduction

1.1 Fonctions et Actions Principales

L'outil **SSL Checker** a pour but d'analyser à quel point un serveur web est bien sécurisé (qualité SSL/TLS).

— **Ce que l'outil doit faire (Objectifs) :** Pour connaître les buts précis du projet, consultez le **STB**, **Section 2.2** (Objectif général) et **2.3** (Objectifs spécifiques).

— **Ce qui est inclus dans le projet (Périmètre) :** Pour voir la liste complète des fonctions (tests de certificats, protocoles, vulnérabilités, etc.), consultez le **STB**, **Section 3** (Périmètre fonctionnel).

— **L'action principale (Cas d'utilisation) :** C'est un utilisateur qui **Lance une analyse**. Cette action regroupe toutes les étapes (récupération du certificat, tests des protocoles, calcul du score, etc.).

1.2 Modules à Tester

Nous devons vérifier tous les composants de l'application.

— **Les parties logicielles à tester :** L'organisation interne de l'outil (les classes $TestX$, $NoteX$, $RapportX$) est expliquée dans le **DAL**, **Section 5** (Architecture Statique).

— **Comment l'analyse se déroule (Flux d'exécution) :** L'enchaînement des étapes (démarrage, tests, calcul des notes, rapports) est détaillé dans le **DAL**, **Section 6** (Fonctionnement Dynamique du Modèle).

1.3 Environnement et Technologies Utilisées

— **Où l'application sera installée (Déploiement) :** L'application est mise dans un conteneur **Docker** et tourne sur une **Machine Virtuelle** fournie par l'université.

— **Les outils principaux (Choix techniques) :** Nous utilisons **Python/Flask** (Backend), **HTML/CSS/JavaScript** (Frontend), et **Nginx/Gunicorn**.

— **Plus de détails techniques :** Pour toutes les configurations, consultez le **DAL**, **Section 4** (Configuration requise et Choix Technologiques).

2 Documents applicables et de référence

Les documents suivants définissent formellement les exigences et l'architecture du projet.

— **Spécification Technique des Besoins (STB)** : Document de référence pour les exigences fonctionnelles (EF) et non fonctionnelles (ENF) du projet.

— **Dossier d'Architecture Logicielle (DAL)** : Document décrivant l'architecture logicielle, les composants et l'environnement technique.

3 Terminologie et sigles utilisés

— **STB** : Spécification Technique des Besoins

— **DAL** : Dossier d'Architecture Logicielle

— **FQDN** : Fully Qualified Domain Name (Nom de domaine complet)

— **EF-xx** : Exigence Fonctionnelle (de la STB)

— **ENF-xx** : Exigence Non Fonctionnelle (de la STB)

— **Cipher Suite** : Ensemble d'algorithmes utilisés pour sécuriser une connexion TLS/SSL

— **Heartbleed** : Faille de sécurité critique dans certaines versions d'OpenSSL

— **WSGI** : Web Server Gateway Interface, le protocole de communication standard entre NGINX et FLASK

Pour la liste complète : Se référer à la STB et le DAL, Section 1.

4 Environnement de test

4.1 Site et Plateforme de Test

— **Site** : Environnement de pré-production/validation (VM de l'université).

— **Degré de Représentativité** : 100%. L'application est conteneurisée (Docker) pour garantir que l'environnement de test est rigoureusement identique à la production.

4.2 Configurations Matérielles et Logicielles Utilisées

Type	Composant	Détails	Réf STB
Système	Système d'exploitation	Linux (environnement VM)	ENF-08
Conteneur	Plateforme	Docker	ENF-08
Serveur Web	Proxy / WSGI	Nginx / Gunicorn	ENF-02
Backend	Logique métier	Python 3 + Flask	ENF-08
Interface	Frontend	HTML, CSS, JavaScript	ENF-03
Librairies	Analyse Crypto	OpenSSL, Cryptography	-

TABLE 1 – Configuration logicielle et matérielle.

4.3 Jeu de Données de Test

Les jeux de données seront basés sur des adresses FQDN réelles ou simulées couvrant les scénarios critiques. Ils sont détaillés dans la section **Jeux de données de test (Section 9)** .

4.4 Contraintes à Prendre en Compte

— **Disponibilité des Cibles** : Le succès de certains tests (EF-11/12) dépend de la disponibilité de serveurs cibles vulnérables.

— **Performance** : Le temps d'analyse doit rester raisonnable.

— **Sécurité** : L'outil ne doit pas être exploitable par des injections.

5 Responsabilités

5.1 Conception des tests

— **Sous-groupes :** Chaque sous-groupe technique rédige ses fiches de tests.

— **Chef d'Equipe :** Valide la couverture des exigences.

5.2 Fourniture des données de test

C'est aux différents sous-groupes de fournir leurs propres données de test (création de conteneurs Docker vulnérables, identification de sites `badssl.com`).

5.3 Exécution des tests

— **Sous-groupes :** Tests unitaires et techniques.

— **Équipe complète :** Tests système et recette.

— **Client :** Validation finale.

6 Stratégie de tests

6.1 Approche et Phases

Phase 1 : Tests Unitaires

Vérification isolée des modules (`TestX`) en local.

Phase 2 : Tests d'Intégration

Vérification de l'orchestration par `TestGlobal`, du calcul de la note par `NoteGlobal` et de la génération du rapport par `RapportGlobal`.

Phase 3 : Tests Système

Validation du parcours utilisateur complet via l'interface Web.

6.2 Ordre d'exécution

1. Certificats → 2. Protocoles/Ciphers → 3. Echange de clés → 4. Vulnérabilités → 5. Ports → 6. Note → 7. Interface.

7 Gestion des anomalies

— **Bloquante :** Crash ou impossibilité d'analyse.

— **Majeure :** Résultat faux (Faux négatif de sécurité).

— **Mineure :** Défaut ergonomique.

8 Procédures de test

8.1 Module TestCertificat (Certificat)

Objet testé : Module TestCertificat / Moteur d'analyse SSL

Objectif : Vérifier que l'outil récupère, analyse et note correctement un certificat valide et sécurisé, et qu'il sanctionne les certificats non valides

Procédure N°1 : Analyse d'un Certificat Valide

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Lancer l'analyse avec le jeu de données [J1] (Site valide)	Connexion socket établie, Handshake SSL réussi	EF-03	
2	Le système parse le certificat via la librairie Cryptography	Objet X.509 créé via Cryptography sans erreur	EF-03	
3	Vérifier l'affichage de l'Autorité (Issuer) et du Sujet	L'émetteur est identifié (ex : DigiCert) et correspond à une CA de confiance	EF-05	
4	Vérifier l'analyse de la Validité (Dates)	Le système affiche "Valide". Jours restants positifs	EF-04	
5	Vérifier l'analyse de la Chaîne de Certification.	La chaîne est "Complète" et ancrée à une racine de confiance	EF-06	
6	Vérifier l'analyse Extensions (SAN & EKU)	Domaine présent dans SAN, EKU contient "Server Authentication"	EF-22	
7	Vérifier l'analyse Clé Publique & Signature	RSA $>$ 2048 bits, SHA-256	EF-24	
8	Vérifier l'analyse Révocation	Statut "Non Révoqué" (OCSP/CRL)	EF-23	
9	Vérifier la Note Globale Certificat	Note élevée (A ou 90/100)	EF-16	

Procédure N°2 : Détection d'anomalies (Cas aux limites)

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Lancer l'analyse avec [J2] (Certificat Expiré)	Détection de l'expiration. Alerte affichée, note sanctionnée	EF-04	
2	Lancer l'analyse avec [J3] (Auto-signé)	Détection Issuer == Subject. Alerte "Auto-signé"	EF-05	
3	Lancer l'analyse avec [J4] (Mauvais Hostname)	Alerte "Nom de domaine invalide"	EF-22	
4	Lancer l'analyse avec [J5] (Révoqué)	Statut "Revoked". Note F ou 0	EF-23	
5	Lancer l'analyse avec [J6] (Clé Faible/SHA1)	Détection $<$ 2048 bits ou SHA-1. Note éliminatoire	EF-24	

6	Chaîne de certificat incomplète [J7]	Erreur sur la reconstitution de la chaîne	EF-06	

8.2 Module TestProtocole (Protocoles)

Objet testé : Module TestProtocole

Objectif : Vérifier que l'outil détecte les versions de protocoles supportées et gère les cas d'erreur.

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Test générique avec serveurs couvrant tous les cas	Résultat complet comparé aux serveurs de test	EF-07/08	
2	Détection correcte des protocoles obsolètes	Les protocoles obsolètes sont marqués	EF-07/08	
3	Gestion d'un serveur supportant un protocole obsolète	Détection correcte du support obsolète	EF-08	

8.3 Module TestCipher (Cipher Suites)

Objet testé : Fonction TestCipher

Objectif : Identifier correctement toutes les suites supportées et leur ordre de préférence.

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Lancer le teste avec J-1	La liste doit contenir des suites de chiffrement de même type que le sous domaine choisi pour J-1 (ex : AES)	EF-09	
2	Lancer le teste avec J-2	La liste doit être identique à la configuration du serveur (suites de chiffrements + ordre)	EF-21	

8.4 Module TestKeyExchange (Échange de clé)

Objet testé : SSIChecker / Module TestKeyExchange

Objectif : Vérifier que le système renvoie le fonctionnement du module TestKeyExchange.

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Test d'algorithmes Éphémères (DHE/ECDHE) avec J-1	Récupère les suites acceptées. Simule handshake, mesure la taille de la clé (ex : 480 bits)	EF-25 EF-26	

2	Test d'algorithmes Statiques (RSA/DH) avec J-2	Analyse le certificat pour mesurer la taille de la clé publique. Renvoie le résultat	EF-25 EF-26	

8.5 Module TestVulnerabilites (Vulnérabilités)

Objet testé : Module TestVulnerabilites

Objectif : Vérifier que l'outil détecte les failles et sanctionne les serveurs vulnérables.

Procédure N°1 : Validation de Sécurité

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Lancer l'analyse avec [J1] (Site Sécurisé)	Connexion établie, module activé	EF-20	
2	Exécuter le Test Heartbleed	Résultat : "Non Vulnérable"	EF-11	
3	Exécuter le Test POODLE (Config Forcée)	Serveur refuse SSLv3. Résultat : "Non Vulnérable".	EF-12	
4	Exécuter Test Protocoles Obsolètes	Serveur refuse SSLv2/TLS 1.0. Résultat : "Non Vulnérable"	EF-08	
5	Exécuter le Test HSTS	En-tête trouvé. Résultat : "Sécurisé / HSTS Présent"	EF-19	
6	Vérifier le Rapport des Vulnérabilité	Rapport qui indique qu'il n'y a aucune vulnérabilité	-	

Procédure N°2 : Détection de Vulnérabilités Critiques

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Lancer avec [J8] (Heartbleed)	Détection fuite mémoire	EF-11	
2	Lancer avec [J9] (POODLE / SSLv3)	Handshake SSLv3 réussi	EF-12	
3	Lancer avec [J10] (HSTS Manquant)	Pas d'en-tête HSTS	-	
4	Lancer avec [J11] (Cipher Faible/Sweet32)	Handshake 3DES réussi	EF-12	

8.6 Module Scanner de Ports (Ports)

Objet testé : Scanner de Ports

Objectif : Garantir l'interprétation correcte des réponses réseau (TCP/UDP).

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Scan de port ouvert	État détecté : Ouvert	EF-14/15	
2	Scan de port inactif	État détecté : Fermé	EF-14/15	
3	Scan de port filtré	État détecté : Filtré (Timeout)	EF-14/15	
4	Scénario 4 (UDP) : nc -u -lvp 7777	État détecté : Ouvert	EF-14/15	

8.7 Module TestCompatibiliteOS (Compatibilité OS)

Objet testé : Fonction TestCompatibiliteOS

Objectif : Vérifier que le système renvoie la liste complète des OS compatibles.

N°	Actions	Résultats attendus	Exig.	OK/NOK
1	Vérification de compatibilité générale	La fonction retourne une liste complète des OS compatibles	EF-13	
2	Gestion d'un OS non supporté	L'OS est marqué comme non compatible	EF-13	

9 Jeux de données de test

9.1 Module Certificat

— **[J1] Site Sécurisé** : google.com, Port 443. Certificat valide.

— **[J2] Certificat Expiré** : expired.badssl.com. Teste EF-04.

— **[J3] Certificat Auto-signé** : self-signed.badssl.com. Teste EF-05.

— **[J4] Mauvais Domaine** : wrong.host.badssl.com. Teste SAN/Extensions.

— **[J5] Certificat Révoqué** : revoked.badssl.com. Teste Révocation.

— **[J6] Cryptographie Faible** : sha1-intermediate.badssl.com. Teste Signature.

— **[J7] Chaîne incomplète** : incomplete-chain.badssl.com. Teste Chaîne.

9.2 Module Protocoles

— **[J1] Serveurs différents** : tls-v1-2.badssl.com.

— **[J2] Protocoles obsolètes** : tls-v1-0.badssl.com.

9.3 Module Cipher Suites

— **[J1] Énumération des suites de chiffrement** : Site de référence (aes256.badssl.com, 3des.badssl.com)

— **[J2] Ordre de préférence** : localhost (server openssl configuré avec des suites de chiffrement bien ordonnées)

9.4 Module Echange de clé

— **[J-1] Algorithme éphémère** : dh480.badssl.com. Paramètres DH spécifiques.

— **[J-2] Algorithme statique** : localhost (serveur OpenSSL). Configuration manuelle.

9.5 Module Vulnérabilités

— **[J1] Site Sécurisé** : google.com.

— **[J8] Heartbleed** : Conteneur vulnérable.

— **[J9] POODLE** : poodlescan.com (SSLv3).

— **[J10] HSTS Manquant** : http-password.badssl.com.

— **[J11] Cipher Faible** : 3des.badssl.com.

9.6 Module Scan de Ports

Tests basés sur la "Vérité Terrain" avec `netcat` et `ufw` (Scénarios 1 à 4). Validation croisée avec `masscan`.

9.7 Module Compatibilité OS

— **[JOS-01] ListeResultat** : Liste remplie correctement. TestCompatibiliteOS N°1,2 .

10 Couverture de tests

Id Exigence	Description	Procédures	Commentaire
EF-03/04	Présence certificat / Date expiration	Proc 1, 2	Vérifié lors du wrap_socket.
EF-05/06	Émetteur / Chaîne	Proc 1, 2	AnalyseAutorite() et Chaine().
EF-07/08	Versions protocoles / Obsolètes	N° 1,2,3	Test général protocoles.
EF-11	Heartbleed	Proc 1, 2	Paquet malformé.

Id Exigence	Description	Procédures	Commentaire
EF-12	POODLE	Proc 1, 2	Handshake forcé SSLv3.
EF-14/15	Ports Ouverts/Fermés/UDP	N° 1,2,3,4	Netcat TCP/UDP.
EF-22	Extensions (SAN, EKU)	Proc 1, 2	AnalyseExtensions().
EF-23	Révocation	Proc 1, 2	OCSP/CRL.
EF-24	Robustesse crypto	Proc 1, 2	Taille clé, algo signature.
EF-09/10	Liste Ciphers / Ordre	Proc 1	Exhaustivité et ordre.
EF-13	Lister OS compatibles	N° 1,2	Vérification Test-CompatibiliteOS.
EF-25	Liste algos échange clés	N°1	Détermine liste supportée.
EF-26	Taille clé échange	N°1	Détermine taille (bits/courbe).

Bruno Macadre

